



Hacking Ético

Iván Martín Carretero

Índice

01

Introducción

Objetivo

02

03

Legalidad y
Ética

Importancia
Ciberseguridad

04

05

Ataques

¿Qué es el hacking ético?

Es la práctica profesional de analizar sistemas informáticos utilizando las mismas técnicas que los atacantes pero con el objetivo de ayudar a proteger dichos sistemas



Objetivo del Hacking Ético



Legalidad y Ética

El hacking ético siempre se realiza bajo la legalidad y la autorización



Se necesita el
permiso explícito
del propietario del
sistema o empresa



Se realiza en
entornos
controlados o
laboratorios



Se respetan las
normas, políticas y
códigos de conducta

Importancia de la Ciberseguridad

Actualmente estamos en un entorno en el que las amenazas evolucionan constantemente

Prevenir brechas de seguridad

Proteger datos sensibles



Reducir riesgos operativos

Cumplir normativas y estándares de seguridad

Ataques y Mitigación

- Sniffing
- Enumeración de Usuarios
- Password Spraying
- Escalada de Privilegios



Sniffing - Objetivo del ataque



Laboratorio

Máquina Windows

Montamos una máquina con SO Windows qué es en la que vamos a generar tráfico

Máquina Kali Linux

Montamos una máquina Kali Linux en la que vamos a escuchar la red con la herramienta Wireshark

Tarjetas de Red

En cada máquina tendremos que tener una tarjeta de red en modo NAT y añadiremos otra en modo custom1 para que se vean entre ellas

Ping

En windows miramos la IP de la tarjeta de red custom con el comando ipconfig y en Kali con el comando ip a. Hacemos un ping a esa IP para comprobar que se ven las máquinas entre ellas

Mitigación



- Protocolos Cifrados: Usar HTTPS, SSH, TLS
- Redes Wifis Protegidas: Usar la tecnología WPA3 con contraseña robusta
- Segmentación de red: DMZ
- Monitorización: Usar software de monitorización para detectar usuarios no deseados

Enumeración de Usuarios - Objetivo del ataque

Meta

Descubrir los usuarios de un sistema

Protocolos

Se usan protocolos como SMTP o HTTP/S



¿Qué busca?

Posibles usuarios dentro de un sistema

Tipo de ataque

Es un ataque activo ya que interactuamos directamente con el sistema o el usuario

Laboratorio

Aplicación

Creamos un
formulario de
login para
introducir los
usuarios

Mitigación



- Mostrar mensajes genéricos
- Tiempos de respuesta similares
- Límites de intentos
- Captchas

Password Spraying - Objetivo del ataque

Meta

Comprometer varios usuarios probando la misma contraseña

Protocolos

Se buscan protocolos como HTTP/S, LDAP, Kerberos, SSH



¿Qué busca?

Credenciales,
Contraseñas
predecibles, Puntos
de entrada

Tipo de ataque

Es un ataque activo
ya que modificamos,
alteramos o
interactuamos con el
sistema

Laboratorio

Máquina Linux

Montamos una máquina con SO Linux en la que creamos un servidor con FTP y varios usuarios

Máquina Kali Linux

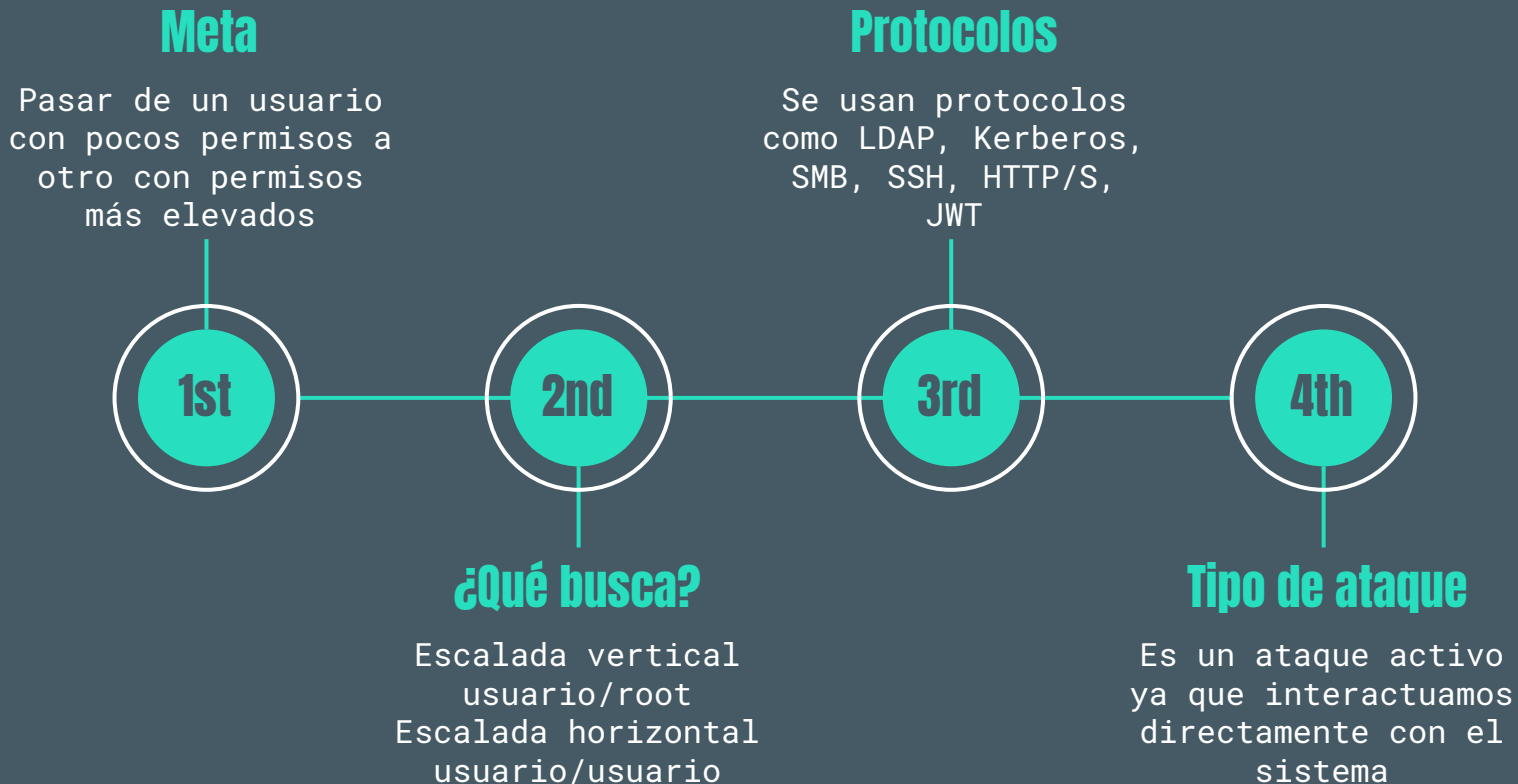
Montamos una máquina Kali Linux en la que vamos a usar herramientas como Hydra

Mitigación



- Contraseñas fuertes: Complejas, longitud y no comunes
- Autenticación Multifactor
- Servicio de bloqueo: Fail2ban, SSHGuard, RdpGuard
- Monitorización: Usar software de monitorización para detectar IPs

Escalada de Privilegios - Objetivo del ataque



Laboratorio

Máquina Linux

Montamos una
máquina con SO
Linux en la que
estarán los
usuarios

Máquina Kali Linux

Montamos una
máquina Kali
Linux en la que
vamos a atacar
y escalar los
privilegios

Mitigación



- Buena configuración de permisos:
Quitar SUID innecesarios
- Actualizar el Kernel y Paquetes
- Buena configuración SUDO
- Proteger variables de entorno como
PATH

¡GRACIAS!

Lo que hoy es seguro, mañana dejará de serlo